SECURITY OPERATIONS CENTRE

Playbook Derived from KC7 Live-Case Threat Hunting Exercises

SOC INCIDENT RESPONSE PLAYBOOK

Ransomware • Insider Threat • Phishing • Hacktivist / Influence Operations

Evidence base: KC7 Cybersecurity — Jojo's Hospital | Encryptodera Financial | Valdoria Times

Version	2.0 Real Evidence Build
Effective Date	April 2026
Prepared by	Akorede Michael Alokan — SOC Analyst
Classification	CONFIDENTIAL — INTERNAL USE ONLY

1. PURPOSE, SCOPE & EVIDENCE BASE

This playbook defines standardized incident response procedures for the four attack categories documented in three KC7 live-case threat hunting exercises. Every detection trigger, runbook step, and escalation threshold in this playbook is grounded in actual log evidence from those investigations not theoretical scenarios.

1.1 Evidence-Based Design

- Case 01 (Jojo's Hospital) drove the Ransomware and Malvertising runbooks.
- Case 02 (Encryptodera Financial) drove the Large-Scale Ransomware GPO Deployment and Insider Threat runbooks.
- Case 03 (Valdoria Times) drove the Phishing / Persistent Backdoor and Influence Operation runbooks.
- Cross-case analysis (Section 4 of the Log Report) drove the Detection Engineering section.

1.2 Objectives

- MTTD target: under 15 minutes for S1/S2 alerts.
- MTTR target: containment within 60 minutes of S1 confirmation.
- 100% incident documentation in ITSM ticketing system, no undocumented response actions.
- All response actions MITRE ATT&CK TTP-mapped in post-incident report.
- Regulatory notifications filed within applicable statutory windows.

2. SEVERITY CLASSIFICATION

All alerts are classified at first triage. Examples are drawn directly from KC7 case evidence.

Level	Label	Trigger Examples (from KC7 Cases)	Response SLA

S1	**CRITICAL**	Ransomware detonation (cases 01, 02); confirmed data exfil; domain admin compromised	Immediate — 15 min
S2	**HIGH**	Persistent backdoor active (plink, cobaltstrike); mass phishing campaign; insider FTP transfer	30 minutes
S3	**MEDIUM**	Phishing email clicked; malicious file executed; unauthorised external login	2 hours
S4	**LOW**	Suspicious browsing (7-zip download); anomalous auth attempt; policy violation	Next business day

3. DETECTION ENGINEERING — SIEM RULES DERIVED FROM KC7 CASES

The following detection signals were identified during the KC7 investigations as missed or late-detected indicators. Implementing these rules directly addresses the dwell times observed (13–26 days).

Detection Signal	Data Source	Why It Matters (Evidence from KC7)
WINWORD / EXCEL spawning cmd.exe or powershell.exe	EDR / Process Log	Cases 01, 02, 03 all used malicious macro docs. WINWORD→cmd is near-universal indicator. Should be S2 alert minimum.
Office app spawning schtasks.exe	EDR / Process Log	Case 03: hacktivist_manifesto.ps1 persistence via schtasks. WINWORD→schtasks = T1053 persistence.
plink.exe execution with -R flag (reverse tunnel)	EDR / Network	Case 03: Both victims used plink -R 3389 to tunnel RDP. plink on non-IT workstations = S2 alert.
Mass file rename events > 200/min on single host	SIEM / File Integrity	Cases 01 and 02: ransomware triggers mass rename. Threshold should auto-isolate host via EDR.
vssadmin.exe or wbadmin.exe with delete/quiet args	Process Log / SIEM	Classic ransomware shadow copy deletion — T1490. Should be S1 autofire rule.
gpupdate /force from non-admin scheduled process	Process / AD Log	Case 02: GPO used to push ransomware to 306 machines. gpupdate from unusual context = alert.
Base64-encoded PowerShell with Invoke-WebRequest	SIEM / Process Log	Case 02: Ransomware downloader obfuscated in base64. IEX + base64 + WebRequest = detection.
nltest /dclist executed on non-DC host	Process Log	Case 02: Domain controller discovery pre-ransomware. nltest from workstation = T1018 alert.
curl.exe with -T or -F flag (upload) to external host	Process Log / Proxy	Cases 01 and 03: data exfiltrated via curl upload. curl upload to unknown IP = DLP trigger.
FTP egress traffic to IP with no 30-day history	Network / Firewall	Case 02: Jane Smith sent data for 27 days via plain FTP. Port 21 egress to new IP = S2 alert.
schtasks /create with /sc hourly + powershell -bypass	Process Log	Case 03: Persistence mechanism exactly. High-precision signature for hacktivist_manifesto pattern.
Renamed Mimikatz variants accessing LSASS	EDR / Behaviour	Case 02: totally_not_mimikatz.exe. LSASS access by any non-whitelisted process = CRITICAL.
7z.exe with -p flag exporting to external IP/domain	Process / Network	Case 03: DankMemes.7z with password = credential reuse. Compressed archive with external upload = exfil.
advanced-ip-scanner.exe or similar on non-IT host	EDR	Case 01: Network mapping after C2. IP scanner on clinical/finance workstation = lateral movement prep.

4. RUNBOOK A — MALVERTISING CHAIN + RANSOMWARE (JOJO'S HOSPITAL PATTERN)

Incident Type	Malvertising → CobaltStrike C2 → Internal Recon → Ransomware + Data Exfil
Severity	S1 — CRITICAL
MITRE TTPs	T1566 | T1204.002 | T1071.001 | T1046 | T1048 | T1105 | T1486 | T1070
KC7 Reference	Case 01 — Jojo's Hospital | andavis / AMFB-MACHINE | lockbyte_ransomer.exe

4.1 Detection Triggers

- User reports inability to open files — extensions changed unexpectedly.
- SIEM: WINWORD.EXE spawns cmd.exe or powershell.exe — macro execution confirmed.
- EDR: cobaltstrike.exe, lockbyte_ransomer.exe, or unknown .exe in %Downloads% or %ProgramData%.
- Network: Outbound connection to external IP on non-standard port following Office document open.
- File integrity: Mass file rename alert exceeding 200 events per 60 seconds.
- DLP: curl.exe or PowerShell Invoke-WebRequest uploading .zip file to external endpoint.

4.2 Response Runbook

#	Phase	Analyst Action	Owner / SLA
1	Detection	Acknowledge SIEM/EDR alert. Open incident ticket. Record: affected hostname, alert time, process chain (parent → child), file hashes, external IPs observed.	L1 Analyst | 0–5 min
2	Triage	Confirm alert is not a false positive. Review process tree — is WINWORD.EXE or Excel the parent? If yes: HIGH confidence malicious macro execution. Classify S2 minimum.	L1 Analyst | 5–10 min
3	Escalate	If cobaltstrike.exe or ransomware binary confirmed: escalate to S1 CRITICAL. Phone SOC Lead and SOC Manager simultaneously. Do not rely on Slack alone.	L1 → L2 | 10 min
4	Isolate	Isolate affected host via EDR remote quarantine or VLAN segregation. Do NOT power off — volatile memory (beacon config, C2 IP) may still be recoverable.	L2 Analyst | 10–20 min
5	Scope	Query SIEM for other hosts contacting same C2 IP (e.g. 93.238.22.122). Check shared drives for staged ransomware (e.g. \\hospital.org\shared\spread_ransomware.exe).	L2 Analyst | 20–40 min
6	IOC Extraction	Extract file hashes. Search VirusTotal and Any.run. Identify ransomware family. Check nomoreransom.org for decryptor. Document all IOCs in ticket.	L2 Analyst | 20–40 min
7	Credential Audit	Check mail server and VPN auth logs for attacker IPs. Case 01: 203.0.113.1 logged into MAIL-SERVER01 as andavis. Force reset all potentially compromised accounts.	L2 Analyst | 30–60 min
8	Evidence Preservation	Capture memory dump before remediation. Hash all artefacts. Document chain of custody. Store in secure evidence share (read-only).	IR Lead | 40–90 min
9	Eradication	Remove ransomware binary and all persistence mechanisms. Check scheduled tasks, registry run keys, startup entries. Verify no lateral tooling remains on shared drives.	IR Lead | 60–120 min
10	Recovery	Restore from last verified clean backup. Test restored systems in isolation before reconnecting to network.	IR Lead + IT Ops | 2–8 hrs

11	Notify	Assess regulatory notification obligations. Hospital/healthcare cases: NDPC 72-hour window; HIPAA equivalent if applicable. Notify CISO and Legal immediately.	SOC Manager | 2–4 hrs
12	PIR	Post-Incident Review within 5 business days. Update SIEM rules, playbook, and firewall/EDR block lists with new IOCs.	All Analysts | 5 days

4.3 Escalation Path

- L1 confirms S2 (macro exec + C2) → escalate to L2 within 10 minutes.
- L2 confirms ransomware → declare S1, phone SOC Lead, activate IR team.
- SOC Manager notifies CISO within 30 minutes of S1 confirmation.
- CISO activates Legal if patient/customer data exfiltration is confirmed.

---

5. RUNBOOK B — DOMAIN-WIDE RANSOMWARE VIA GPO + CREDENTIAL DUMPING (ENCRYPTODERA PATTERN)

Incident Type	Phishing → Account Compromise → Mimikatz → Domain Admin → GPO Ransomware to 306 hosts
Severity	S1 — CRITICAL (enterprise-wide blast radius)
MITRE TTPs	T1566 | T1078 | T1003.001 | T1484.001 | T1059.001 | T1105 | T1486 | T1219
KC7 Reference	Case 02 — Encryptodera Financial | files_go_byebye.exe | .umadbro | 306 machines | 15-day dwell

5.1 Detection Triggers

- SIEM: nltest /dclist executed on workstation (domain controller discovery — T1018).
- EDR: LSASS access by non-whitelisted process (e.g. totally_not_mimikatz.exe — T1003.001).
- AD Log: Service account or non-PAW host authenticating to domain controller.
- SIEM: gpupdate /force executed from non-standard context immediately preceding large-scale file events.
- SIEM: Base64-encoded Invoke-WebRequest downloading executable to ProgramData.
- File integrity: Mass .umadbro or other ransomware extension renames across multiple hosts simultaneously.
- Email DLP: Phishing email from compromised internal account with .exe attachment or external link.

5.2 Response Runbook

#	Phase	Analyst Action	Owner / SLA
1	Detection	Alert fires: mass file renames across multiple hosts OR LSASS credential dump detected. Open P1 incident ticket immediately. Record blast radius — how many hosts are affected?	L1 Analyst | 0–5 min
2	Declare Major Incident	If 10+ hosts affected simultaneously: declare Major Security Incident. Activate IR team. Brief SOC Manager and CISO by phone. This is not an email scenario.	L1/SOC Lead | 5 min
3	Disable GPO / Revoke DC Access	Immediately disable the compromised domain admin account (e.g. lihenry_domain_admin). Block associated IPs at firewall. Lock GPO edit rights. Isolate domain controller from regular traffic.	IR Lead + AD Admin | 10–20 min

4	Identify Source Account	Trace phishing chain back to original compromised account (e.g. bashmelly). Determine all accounts emailed, all sessions active. Disable originating account immediately.	L2 Analyst | 15–30 min
5	Stop Spread	Segment network — isolate all VLANs where ransomware is active. Use EDR to remotely kill files_go_byebye.exe process across remaining live hosts. Disable SMB if lateral spread is confirmed.	IR Lead | 15–45 min
6	Credential Reset — All Privileged Accounts	Force password reset for ALL domain admin accounts, service accounts, and any account that authenticated during attacker dwell window. Disable NTLM where possible.	IAM Team | 30–60 min
7	Scope Full Damage	Count encrypted hosts. Identify earliest infected machine (Case 02: UL8R-MACHINE at 02:30:50). Cross-reference systeminfo command hosts (8 machines) vs encrypted machines (306).	L2 Analyst | 30–90 min
8	IOC Sweep	Block notification-finance-services.com and all related C2 domains at DNS and firewall. Submit hashes to EDR blocklist. Purge files_go_byebye.exe from all ProgramData directories.	SOC / Network | 30–90 min
9	Investigate Insider Concurrent Activity	Run DLP query: any FTP/HTTPS bulk transfers to external IPs during same window? (Case 02: Jane Smith — 182.56.23.121 — discovered during post-incident forensics, not real-time.) This must not be missed.	L2 Analyst | 60–120 min
10	Recovery	Restore from clean backups in priority order: domain controller first, then critical business systems, then endpoints. Verify backup integrity before restoration. Do not trust backups created after initial compromise date.	IR Lead + IT Ops | 4–48 hrs
11	PIR	Full post-incident review. Root cause analysis. Update detection rules — specifically: nltest, gpupdate, base64 PS, LSASS access. Lessons-learned session within 5 days.	All Analysts | 5 days

6. RUNBOOK C — PHISHING + PERSISTENT BACKDOOR + REVERSE TUNNEL (VALDORIA TIMES PATTERN)

Incident Type	Spearphishing Job Lure → Macro → PS1 Backdoor → Scheduled Task Persistence → Plink RDP Tunnel
Severity	S2 — HIGH (persistent access; escalates to S1 if data exfil confirmed)
MITRE TTPs	T1566.002 | T1204.002 | T1059.001 | T1053.005 | T1572 | T1036 | T1560 | T1048
KC7 Reference	Case 03 — Valdoria Times | hacktivist_manifesto.ps1 | plink.exe | $had0w / thruthW!llS3tUfree

6.1 Detection Triggers

- SIEM: WINWORD.EXE spawning powershell.exe → creating file in C:\ProgramData\.
- Process Log: schtasks /create with /sc hourly + -ExecutionPolicy Bypass.
- Network: plink.exe initiating outbound SSH connection on port 22 to external IP.
- Network: Reverse port forward pattern on RDP port (3389) via SSH tunnel.
- Email: External sender using free Gmail with recruitment-themed subject line and external docx link.
- File event: cmd.exe executing 'move' command to rename a downloaded file over an existing document name.
- Network: 7z.exe compressing local files followed immediately by curl upload to external domain.

6.2 Response Runbook

#	Phase	Analyst Action	Owner / SLA
1	Detection	Alert fires on scheduled task creation or plink.exe execution. Open incident ticket. Record: host, username, plink destination IP, task name, PS1 file path.	L1 Analyst | 0–5 min
2	Classify	Persistent backdoor = S2 minimum. If plink tunnel is active and RDP session observed: escalate to S1. Actor may already have interactive access to the host.	L1 Analyst | 5–10 min
3	Kill the Tunnel	Terminate plink.exe process via EDR. Block destination IP (136.130.190.181 / 168.57.191.100) at perimeter firewall immediately. Actor loses RDP access.	L2 Analyst | 10–20 min
4	Remove Persistence	Delete hacktivist_manifesto.ps1 from C:\ProgramData\. Remove scheduled task 'Hacktivist Manifesto'. Verify no secondary scheduled tasks referencing ProgramData.	L2 Analyst | 15–30 min
5	Scope — Other Victims	Search SIEM for same PS1 filename on other hosts. Case 03: both Sonia and Ronnie had hacktivist_manifesto.ps1 — different hashes but same name. Filename is a hunt pivot.	L2 Analyst | 20–40 min
6	Email Investigation	Retrieve original phishing email from gateway logs. Extract sender address, link domain, file hash. Block sender domain and link domain at gateway. Purge email from all mailboxes via admin sweep.	L1/L2 Analyst | 30–60 min
7	Content Integrity Check	Case 03 unique: verify whether any fabricated documents were sent to internal users or publication queues. Search mail logs for 'OpEdFinal' or similar recent internal file-share links sent from compromised accounts.	L2 Analyst | 30–60 min
8	Credential Reset	Reset passwords for all compromised accounts. Audit OAuth app consents and active sessions. Revoke all tokens for affected users.	IAM / L2 | 30–60 min
9	Exfil Investigation	Check proxy/network logs for curl uploads with -F flag, 7z archives sent to external IPs, and any unusual HTTPS POST to new external domains within attacker's active window.	L2 Analyst | 45–90 min
10	Notify	Assess data and content breach. Case 03: fabricated content sent to printer = reputational and legal exposure. Notify Legal, Editorial Leadership, and CISO immediately.	SOC Manager | 1–2 hrs
11	PIR	Update email gateway rules. Add plink and schtasks signatures. Document full attack chain for playbook update.	All Analysts | 5 days

7. RUNBOOK D — INSIDER THREAT & SLOW DATA EXFILTRATION (JANE SMITH / ENCRYPTODERA PATTERN)

Incident Type	Insider Threat — Long-Duration FTP Exfiltration of Sensitive Financial/Crypto Data
Severity	S1 — CRITICAL (data breach in progress; legal and regulatory implications)
MITRE TTPs	T1048.003 – Exfil over FTP | T1059 – Obfuscated PS1 | T1530 – Cloud/Sensitive Data | T1204
KC7 Reference	Case 02 — Jane Smith (jasmith) | ftp_client.exe | 27 days | 208,138 bytes | IP 182.56.23.121

7.1 Insider Threat Warning Indicators (Pre-Incident)

- Recently hired employee given access to sensitive assets within days of start date.
- Browsing history: research into secure file transfer methods, 7-zip, USB usage — outside job role.
- External email contact with suspicious domain (e.g. westealurcrypto.com) not related to business.
- Downloads of non-business tools: ftp_client.exe, crypto_stealer.exe to personal directory paths.
- Network: FTP traffic to external IP with no business justification.
- UEBA: Daily data transfer volume 10x+ above individual baseline.

7.2 CRITICAL Rule — Covert Investigation Protocol

Unlike external attacks, insider threat investigations must be treated with extreme operational security. Alerting the suspected insider to the investigation will result in evidence destruction. ALL actions below must be authorised and covert until legal/HR action is taken.

#	Phase	Analyst Action	Owner / SLA
1	Detect	DLP or UEBA alert fires on bulk external data transfer. Open RESTRICTED ticket — limit visibility to SOC Lead, CISO, Legal, HR only. Do NOT notify the suspected insider.	L2 Analyst | Immediate
2	Covert Monitor	Enable enhanced logging on suspect account and associated hosts. Do NOT quarantine or block — preserve evidence and allow continued monitoring under legal authority.	SOC Lead | 0–30 min
3	Legal Notification	Immediately brief CISO and Legal. Insider threat evidence is subject to chain-of-custody requirements and employment law. Every subsequent action must be legally defensible.	SOC Manager | 15 min
4	Decode Obfuscation	If exfil command is obfuscated (Case 02: base64 + string reversal): decode in full and document the decoded command in the ticket. Jane's FTP command revealed: IP, port, username, password, destination path, and schedule.	L2 Analyst | 30–60 min
5	Establish Scope	Determine: what data was accessed, what was transferred, to where, over how long, total volume. Jane: 27 days, 208,138 bytes, FTP to 182.56.23.121, daily schedule.	L2 Analyst | 60–180 min
6	Evidence Collection	Collect and hash: FTP logs, proxy logs, DLP alerts, email logs, file access audit trail, endpoint forensic image. Store in secure evidence repository with chain-of-custody log.	L2 + IR Lead | 60–180 min
7	Account Suspension	Upon legal and HR authorisation: disable suspect account, revoke all access tokens, VPN, and cloud credentials. Coordinate with HR for employment action before account action (simultaneous preferred).	SOC Lead + HR | Legal approval required
8	Regulatory Assessment	Assess breach notification obligations: was regulated data transferred? (Case 02: crypto wallet data + financial records.) NDPC, PCI-DSS, or sector-specific notification may apply.	Compliance + Legal | 24–72 hrs
9	PIR	Full forensic report. Update DLP from monitor to enforcement mode. Review least-privilege policies. Implement FTP egress block on all endpoints without business justification.	All + Compliance | 10 days

8. ESCALATION & NOTIFICATION MATRIX

Role	Contact Method	Activation Trigger	Authority / Responsibility
L1 SOC Analyst	Ticket + Slack	Any alert received	Triage, classify, initial documentation
L2 SOC Analyst	Slack + Phone	S2 confirmed by L1 / S1 immediate	Containment, investigation, IOC extraction
SOC Lead / IR Lead	Phone (primary)	S1 confirmed — any category	Declare major incident, coordinate all response

SOC Manager	Phone + Email	S1 within 15 min / S2 within 30 min	Activate IR team, brief CISO
CISO	Phone direct	S1 with confirmed data impact	Executive decisions, regulatory strategy
Legal / Compliance	Email + Phone	Any data breach or insider case	Legal privilege, regulatory notifications
HR	Secure channel only	Insider threat confirmed	Employment action, investigation support
IT / IAM	Ticket + Phone	Account lockdown or GPO change needed	Technical execution of isolation/reset tasks

9. POST-INCIDENT REVIEW (PIR) REQUIREMENTS

Every S1 and S2 incident requires a completed PIR within 5 business days. The PIR is the primary tool for improving detection coverage and must include all of the following.

1. Executive summary — non-technical, maximum 1 page. What happened, what was impacted, what was done.
2. Full incident timeline from first attacker action to final remediation step — with exact timestamps.
3. Root cause analysis — what allowed the attacker to succeed at each stage.
4. MITRE ATT&CK TTP mapping — every attacker technique identified in the investigation.
5. Detection gaps — what should have fired an alert and did not, and why.
6. Corrective actions — specific SIEM rule changes, DLP policy updates, IAM controls — with owners and deadlines.
7. Playbook update log — which sections of this playbook were updated as a result of this incident.

10. REGULATORY COMPLIANCE REFERENCES

- NDPC Act 2023 (Nigeria) — 72-hour breach notification to NDPC and affected data subjects for personal data exposure.
- PCI-DSS v4.0 — Incident response planning (Req 12.10), forensic investigation procedures, cardholder data breach notification.
- ISO/IEC 27001:2022 — Annex A Control 5.24: Information security incident management planning and preparation.
- CBN Cybersecurity Framework — Financial institutions must report cyber incidents to CBN within 24 hours of confirmed breach.
- HIPAA (if applicable — healthcare cases like Case 01): Breach notification to HHS and affected individuals within 60 days.